CERTIFIED ETHICAL HACKER | FOOTPRINTING LAB GUIDE

Footprinting Labs

Step-by-step walkthroughs for 12 OSINT and reconnaissance labs

Lab	Topic	Tool / resource
1	Advanced Google hacking techniques	Google, Google Hacking Database
2	Video search engines	YouTube, Google Videos, Vimeo, YouTube DataViewer
3	FTP search engines	NAPALM FTP Indexer and similar
4	IoT search engines	Shodan, Censys, Thingful
5	Domains and sub-domains	Netcraft
6	Personal information (people search)	PeekYou
7	Email list	theHarvester
8	Target website details	ping
9	Target website details	Website Informer
10	Company data extraction	Web Data Extractor
11	Website mirroring	HTTrack Website Copier
12	Wordlist from website	CeWL

Important: Use only your own organization, a lab target, or one you have **written authorization** to assess. People-search, email and social data are personal data: collect only what the engagement needs, protect it, and never use it to harass or deceive anyone outside the agreed scope.

Contents

How to Use This Guide	3
Lab 1: Gather Information Using Advanced Google Hacking Techniques	3
Lab 2: Gather Information from Video Search Engines	4
Lab 3: Gather Information from FTP Search Engines	4
Lab 4: Gather Information from IoT Search Engines	5
Lab 5: Find a Company's Domains and Sub-domains Using Netcraft	6
Lab 6: Gather Personal Information Using PeekYou	6
Lab 7: Gather an Email List Using theHarvester	7
Lab 8: Gather Information About a Target Website Using ping	7
Lab 9: Gather Information About a Target Website Using Website Informer	8
Lab 10: Extract a Company's Data Using Web Data Extractor	9
Lab 11: Mirror the Target Website Using HTTrack Website Copier	9
Lab 12: Gather a Wordlist from the Target Website Using CeWL	10
Lab Quick Reference	11
Practice Questions	11

How to Use This Guide

Each lab follows the same pattern: **objective, requirements, steps, what to record, and the defender's takeaway**. Throughout, **example.com** and similar placeholders stand for your authorized target. Web tools change their layout and free-tier limits often, so treat button names as a guide and check the live site. Commands were written from standard tool behaviour and not re-run here; confirm options with *--help* or *man* on your version.

Evidence template (use for every lab)

Field	What to write
Source / tool	Tool name, version or URL, date and time of query
Query used	Exact search string, command or filter
Finding	Domain, host, IP, email, file, person (as in-scope)
Sensitivity	Public / internal / confidential; link to screenshot
Recommendation	What the organization should change

Passive labs (1-7, 9) use public sources without touching the target's servers. Labs 8, 10, 11 and 12 (ping, Web Data Extractor, HTTrack, CeWL) **contact the target directly** and appear in its logs.

Lab 1: Gather Information Using Advanced Google Hacking Techniques

Objective: use Google operators to find information about your target that is publicly indexed: sub-domains, documents, login pages, directory listings and error messages. **Requirements:** a web browser; (optional) the Google Hacking Database at exploit-db.com.

Steps

- Open Google and start with the target domain: *site:example.com*. Note the number of indexed pages.
- Narrow by content type, one operator at a time, and combine them.
- Exclude noise with **-** (for example *-www* shows other sub-domains).
- Browse the Google Hacking Database, pick dorks by category (files containing passwords, sensitive directories, error messages, login portals) and add *site:example.com* to each.
- Open **Advanced Search** (google.com/advanced_search) to filter by file type, region, last update and usage rights, then record useful URLs.

Goal	Example query
Sub-domains	site:example.com -www
Documents	site:example.com filetype:pdf OR filetype:xlsx OR filetype:docx
Directory listings	site:example.com intitle:"index of"
Login pages	site:example.com inurl:login OR inurl:admin OR intitle:"sign in"
Confidential words	site:example.com intext:"confidential" OR intext:"internal use only"
Config and logs	site:example.com ext:log OR ext:conf OR ext:env
Error messages	site:example.com intext:"sql syntax" OR intext:"stack trace"

Goal	Example query
Staff emails	site:example.com intext:"@example.com"
Cached copy	cache:example.com/page (where supported)

Record: sub-domains, document names and metadata authors, exposed directories, login URLs, technology hints. **Takeaway:** remove or protect what should not be indexed, use authentication rather than *robots.txt*, and run these dorks against your own domain regularly.

Lab 2: Gather Information from Video Search Engines

Objective: find videos that expose information about the organization: office layouts, badges, screens, whiteboards, conference talks, product demos and staff names. **Requirements:** browser; YouTube, Google Videos, Vimeo, Yahoo Video, Dailymotion; (optional) YouTube DataViewer or InVID.

- Search the company name on YouTube, then use **Filters** (upload date, type, duration, features) to narrow results.
- Search variations: company name plus *tour*, *conference*, *webinar*, *demo*, *training*, *CEO*, *office*, product names, event names.
- Search the same terms on Google Videos (Tools: duration, date) and Vimeo.
- Open interesting videos. Watch for: building exteriors and signs, visitor/ID badge designs, monitors showing software, passwords on sticky notes, whiteboards, server rooms, speaker names and titles.
- Check titles, descriptions, comments and linked channels for staff and technology names.
- Use **YouTube DataViewer** (Amnesty International) to pull exact upload time and thumbnails; reverse-search thumbnails with Google Lens or TinEye to find re-uploads.

Record: video URLs, speakers, systems visible on screen, locations. **Takeaway:** review marketing and conference recordings before publication; blur screens, badges and whiteboards; restrict filming in sensitive areas.

Lab 3: Gather Information from FTP Search Engines

Objective: find files hosted on publicly reachable FTP servers that belong to or mention the target. **Requirements:** an FTP search engine such as **NAPALM FTP Indexer**, Mamont or similar. Availability of these services changes, so search the web for a current FTP indexer if one is offline.

- Open the FTP search engine in your browser.
- Enter a keyword: the company name, product name, project name, or a file extension that matters to the audit (for example *.pdf*, *.xls*, *.bak*).
- Filter by file size, date or server if the engine supports it.
- Review the hit list: server addresses, directory paths, file names and sizes. Compare server IPs to the target's netblock to confirm ownership.
- Do **not** download or open sensitive files beyond what your scope allows. Record the path and notify the client.

```
# Manual follow-up on a server you are authorized to test
ftp ftp.example.com           # try user: anonymous
```

```
nmap -p 21 --script ftp-anon,ftp-syst ftp.example.com
```

Record: exposed servers, anonymous access, sensitive filenames. **Takeaway:** disable anonymous FTP, move to SFTP/FTPS, and keep internal data off Internet-facing file servers.

Lab 4: Gather Information from IoT Search Engines

Objective: find the target's Internet-facing devices and services (web servers, cameras, routers, industrial controllers) and their banners. **Requirements:** a free account on **Shodan** (shodan.io) or **Censys** (search.censys.io); Thingful for sensor data.

Shodan filters

Filter	Example
org:	org:"Example Corp"
net:	net:203.0.113.0/24
hostname:	hostname:example.com
port:	port:3389 org:"Example Corp"
product:	product:nginx org:"Example Corp"
country: / city:	country:IN city:Mumbai org:"Example Corp"
os:	os:"Windows Server 2008" org:"Example Corp"
ssl.cert.subject.cn:	ssl.cert.subject.cn:example.com
vuln: (paid)	vuln:CVE-2021-44228 org:"Example Corp"

- Sign in and search for the organization with **org:**, **net:** or **ssl.cert.subject.cn:**.
- Open each result to see ports, banners, software versions, certificates and geolocation.
- Use **Explore** and **Images** tabs for categories such as webcams or industrial systems, restricted to your target's netblock.
- Repeat in **Censys** (for example *services.port=443 and autonomous_system.name="Example"*) and compare results.

```
pip install shodan
shodan init YOUR_API_KEY
shodan host 203.0.113.10               # ports, banners, vulns for one IP
shodan search "org:\"Example Corp\""   # list matches (query credits apply)
shodan count net:203.0.113.0/24
```

Record: exposed services, outdated versions, default pages, remote admin ports. **Takeaway:** every service visible here is visible to attackers. Remove unneeded exposure, change default credentials and keep firmware current. Query only your own scope.

Lab 5: Find a Company's Domains and Sub-domains Using Netcraft

Objective: enumerate the company's domains, sub-domains and hosting details passively. **Requirements:** browser; Netcraft tools (searchdns.netcraft.com and sitereport.netcraft.com). Newer Netcraft pages may be moved; use the Netcraft site's Resources menu if a link has changed.

- Open **Netcraft Search DNS** and choose the search type *site contains* (or hostname).
- Enter the domain, for example *.example.com* or *example*, and run the search.
- Review the results: each sub-domain with its first-seen date, netblock owner, operating system and IP address.
- Open a result's **Site Report** (or enter the domain at sitereport.netcraft.com).
- Read the report sections: **Background** (registrar, dates, site title), **Network** (IP, name server, DNS admin, netblock owner, hosting company, reverse DNS), **Hosting History**, **SSL/TLS**, **Web technologies** and **Web Trackers**.
- Export or copy the list of sub-domains and IPs for later scanning (Labs 7 to 12).

Netcraft field	Why it matters
Netblock owner	Confirms whether the host is on the company's own range or a cloud/hosting provider
Name server / DNS admin	Shows DNS provider and contact for DNS footprinting
OS and web server	Narrows later vulnerability research
Hosting history	Previous providers and IPs reveal older infrastructure
First seen	Very old or very recent hosts may be forgotten or experimental

Cross-check with **sublist3r -d example.com** and **crt.sh** (certificate transparency) for sub-domains Netcraft may not list.

Lab 6: Gather Personal Information Using PeekYou

Objective: see what an online people-search service reveals about an individual, to judge social-engineering risk. **Requirements:** browser; PeekYou (peekyou.com). **Privacy:** run this lab on yourself, a consenting volunteer, or a person named in your authorized scope. Do not profile private individuals out of curiosity.

- Open PeekYou and enter the person's **first name** and **last name**; add a city or state to narrow the results.
- Click Search and review the matching profiles.
- Open the best match and note: approximate age, current and past locations, linked social media profiles, usernames, photos, education and workplace, possible relatives.
- Cross-check using other sources (LinkedIn, company site) to confirm the right person; people search data is often wrong or outdated.
- Search the username on other platforms (Sherlock, Namechk) to follow the digital trail.

Record: only what is relevant (job role, public profile links, location of workplace). **Takeaway:** staff should know their data is aggregated. Use the service's **opt-out/removal** request page, tighten social privacy

settings and avoid reusing usernames.

Lab 7: Gather an Email List Using theHarvester

Objective: collect public email addresses, names, hosts and sub-domains for a domain from open sources. **Requirements:** Kali/Parrot (theHarvester preinstalled) or *pip*/GitHub install. Many sources now need **API keys** (set them in the tool's api-keys file); the list of working sources changes between versions, so run *theHarvester -h* first.

Option	Meaning
-d	Domain to search
-b	Data source (e.g. crtsh, duckduckgo, bing, otx, hackertarget, rapiddns, urlscan, all)
-l	Limit the number of results
-s	Start at result number
-f	Save results to file (HTML and XML)
-r	Resolve discovered hosts via DNS

```
theHarvester -h                                  # list supported sources
theHarvester -d example.com -b crtsh -l 200
theHarvester -d example.com -b duckduckgo,bing -l 200 -f result
theHarvester -d example.com -b all -f result_all  # many sources (some need API keys)
cat result.xml | grep -o '[A-Za-z0-9._-]*@example.com' | sort -u
```

- Run the tool for the target domain with one source, then add more sources.
- Collect the **emails** (for phishing-awareness testing and username formats) and **hosts / sub-domains** (for scanning).
- Deduplicate and verify addresses; note the naming pattern (first.last@, flast@).

Takeaway: staff emails are easy to harvest. Use awareness training, email filtering, role addresses for public contact pages and monitor for breaches.

Lab 8: Gather Information About a Target Website Using ping

Objective: use **ping** to find the IP address, estimate the operating system from TTL, measure reachability and discover the maximum transmission unit (MTU). This sends ICMP packets to the target, so it is an **active** technique. **Requirements:** Windows Command Prompt or any Linux/macOS terminal.

Step 1: IP address and TTL

```
ping www.example.com             # Windows: 4 echos; Linux: continuous (Ctrl+C)
ping -c 4 www.example.com        # Linux/macOS: 4 packets
```

The reply shows the resolved **IP address**, round-trip time, and **TTL**. Initial TTL values: Linux/Unix 64, Windows 128, network devices 255. A reply of TTL=118 suggests an initial 128 (Windows) about 10 hops away; TTL=54 suggests 64 (Linux) about 10 hops away.

Step 2: Find the maximum frame size (MTU)

```
:: Windows: -f sets Don't Fragment, -l sets payload size
```

```
ping www.example.com -f -l 1500
ping www.example.com -f -l 1472
# Linux/macOS: -M do = don't fragment (macOS: -D), -s = payload size
ping -M do -s 1472 -c 2 www.example.com
```

If the reply says **Packet needs to be fragmented but DF set**, reduce the size until replies succeed. **MTU = largest working payload + 28 bytes** (20 IP header + 8 ICMP header). 1472 + 28 = 1500, the common Ethernet MTU.

Step 3: Estimate hops with TTL

```
ping www.example.com -i 3 -n 1        # Windows: set TTL to 3
ping -t 3 -c 1 www.example.com        # Linux: -t sets TTL
```

Raise TTL step by step: **TTL expired in transit** replies come from each router on the path until the final host answers. This is manual traceroute. If there is no reply, ICMP may be blocked: try *nmap -sn -PS80 www.example.com* or *tracert*.

Takeaway: filter inbound ICMP except what is needed, but remember blocking ping does not hide a host that has open ports.

Lab 9: Gather Information About a Target Website Using Website Informer

Objective: collect registration, DNS, hosting and traffic details of a website from one passive source.
Requirements: browser; website-informer.com.

- Open **website-informer.com** and enter the target domain in the search box.
- On the overview page, note: site title and description, owner/organization, creation date, expiry date, web server software, IP address and country, traffic rank estimates.
- Open the **Whois** information: registrar, registrant, contacts, name servers.
- Open the **DNS records** tab: A, MX, NS, TXT and others.
- Check **Related / similar sites** and other domains on the same IP or with the same owner for additional targets.
- Capture screenshots with the query date for the report.

Data point	Use in the engagement
Registrant and contacts	Social-engineering targets and scope confirmation
Name servers	DNS footprinting and zone transfer tests
IP and hosting	Netblock mapping and cloud vs on-premises
Server software	Initial vulnerability research
Other domains on same IP	Shared hosting or related sites to check for scope

Verify with **whois** and **dig**; third-party sites may cache old data.

Lab 10: Extract a Company's Data Using Web Data Extractor

Objective: crawl a website and extract emails, phone numbers, fax numbers, URLs and meta tags into a structured list. **Requirements:** Windows machine with Web Data Extractor (WDE) installed; target website within scope. This tool **crawls the target directly** and appears in its logs. Exact menu names depend on the version.

- Launch **Web Data Extractor** and click **New** to start a new session.
- Enter the target URL (for example https://www.example.com) in the start URL box.
- Tick what to extract: **meta tags**, **emails**, **phones**, **faxes**, **URLs** (and links).
- Configure the crawl depth and limits (for example depth 2 to 3, limited pages) and whether to stay on the same domain, to avoid overloading the target.
- Click **Start** and let the spider run; watch progress and the page counter.
- When finished, review the tabs: **Meta tags** (titles, descriptions, keywords), **Emails**, **Phones**, **Faxes**, **URLs**.
- Click **Save** and export to CSV or Excel.

Record: email naming format, phone/fax numbers, sub-pages, keywords. Use the contact list to prepare phishing-awareness tests or targeted social engineering *only within scope*. **Takeaway:** avoid publishing direct staff addresses; use contact forms; add rate-limits and bot detection.

Lab 11: Mirror the Target Website Using HTTrack Website Copier

Objective: download a copy of the website for offline analysis (HTML comments, hidden fields, scripts, directory structure, documents). **Requirements:** WinHTTrack on Windows, or *httrack* on Linux. Mirroring **contacts the target directly** and can create load: use modest limits and only with permission.

WinHTTrack (GUI)

- Launch **WinHTTrack** and click **Next**.
- Enter a **project name** and **base path** for the saved copy; click Next.
- Choose **Download web site(s)** as the action, and enter the target URL in the Web Addresses box.
- Click **Set options**: set limits (mirror depth, maximum size), connections, and review scan rules. Leave robots.txt handling at default unless your authorization says otherwise.
- Click Next, then Finish to start. Wait for the mirror to complete.
- Open the project folder and run **index.html** in a browser to browse the copy.

HTTrack (command line)

```
httrack "https://www.example.com" -O ./example_mirror -r3 -c4 -v
# -O output folder   -r3 depth 3   -c4 four connections   -v verbose
httrack --update -O ./example_mirror              # refresh an existing mirror
```

What to look for offline

- HTML and JavaScript comments, TODO notes, developer names

- Hidden form fields, API endpoints, internal URLs and sub-domains
- Linked PDFs and Office files (extract metadata with exiftool)
- Software and version strings in scripts and CSS paths
- Directory structure and unusual folders (backup, old, test)

```
grep -rniE "password|api[_-]?key|TODO|internal|@example.com" ./example_mirror
exiftool -a -u -r ./example_mirror/*.pdf | grep -iE "author|creator|producer"
```

Takeaway: assume everything served to the browser can be copied. Remove comments and secrets from production code, strip metadata from files, and rate-limit crawlers.

Lab 12: Gather a Wordlist from the Target Website Using CeWL

Objective: spider the target site and build a custom wordlist of terms used by the organization, for use in password-strength audits **of systems in scope**. **Requirements:** Kali/Parrot (CeWL preinstalled). CeWL fetches pages directly from the target.

Option	Meaning
-d N	Spider depth (default 2)
-m N	Minimum word length (default 3)
-x N	Maximum word length
-w file	Write the wordlist to a file
-e	Also collect email addresses
--with-numbers	Include words containing digits
-c	Show the count of each word
-a	Extract metadata from linked documents (with -m / exif options)
-v	Verbose output

```
cewl -h
cewl -d 2 -m 5 -w wordlist.txt https://www.example.com
cewl -d 3 -m 6 -e -w words_emails.txt https://www.example.com
cewl -d 2 -m 5 -c https://www.example.com | head -20       # most frequent words
wc -l wordlist.txt                                          # number of words
sort -u wordlist.txt -o wordlist_unique.txt
```

- Run CeWL with depth 2 and a minimum length of 5 characters, saving to a file.
- Open the file: it holds product names, locations, staff names and jargon from the site.
- Clean and deduplicate; optionally add mutation rules (case changes, numbers, years) in the password-audit tool you use.
- Use the list only against authentication systems that are in scope and covered by your rules of engagement.

Takeaway: staff often build passwords from company words. Ban such passwords with a password filter, require long passphrases and MFA, and monitor for password spraying.

Lab Quick Reference

Lab	Key command / query	Contact target?
1 Google hacking	site:example.com filetype:pdf / intitle:"index of"	No
2 Video search	YouTube filters; YouTube DataViewer	No
3 FTP search	NAPALM FTP Indexer keyword search	No
4 IoT search	shodan host IP; org: net: port: filters	No
5 Netcraft	Search DNS: site contains .example.com; Site Report	No
6 PeekYou	First name + last name + location	No
7 theHarvester	theHarvester -d example.com -b crtsh -l 200 -f out	Mostly no
8 ping	ping -f -l 1472 host ; ping -i N host	Yes (ICMP)
9 Website Informer	Search the domain at website-informer.com	No
10 Web Data Extractor	New session, URL, extract emails/phones/meta tags	Yes (crawl)
11 HTTrack	httrack URL -O dir -r3	Yes (crawl)
12 CeWL	cewl -d 2 -m 5 -w wordlist.txt URL	Yes (crawl)

Practice Questions

#	Question	Answer
1	Which Google operator limits a search to one domain?	site:
2	Which operator finds open directory listings?	intitle:"index of"
3	Name two IoT search engines.	Shodan and Censys (also Thingful).
4	Which Shodan filter searches by organization name?	org:
5	Which Netcraft search type lists sub-domains of a domain?	Search DNS with the 'site contains' option.
6	What does an initial TTL of 128 usually indicate?	A Windows system (Linux/Unix is typically 64, network devices 255).
7	How do you compute MTU from a ping test?	Largest working payload (with DF set) + 28 bytes (20 IP + 8 ICMP).
8	Which ping option on Windows sets the Don't Fragment flag?	-f (with -l to set the payload size).
9	What does theHarvester's -b option select?	The data source to search.
10	What information does Web Data Extractor collect?	Meta tags, emails, phone and fax numbers, and URLs.
11	What is the difference between HTTrack and CeWL output?	HTTrack saves an offline copy of the site; CeWL builds a wordlist of words found on it.
12	Why is the CeWL wordlist useful to defenders?	It shows the company-specific words attackers would use, so those can be banned in passwords.
13	Which labs in this guide contact the target directly?	Ping, Web Data Extractor, HTTrack and CeWL.

#	Question	Answer
14	Name two defences against Google hacking exposure.	Remove sensitive files from indexed areas, require authentication, and regularly dork your own domain.

Keep screenshots and the evidence template from each lab, and delete personal data when the engagement ends.